

Human Factors, Safety, Security and Ethics

COM00189M Assessment

Question 1

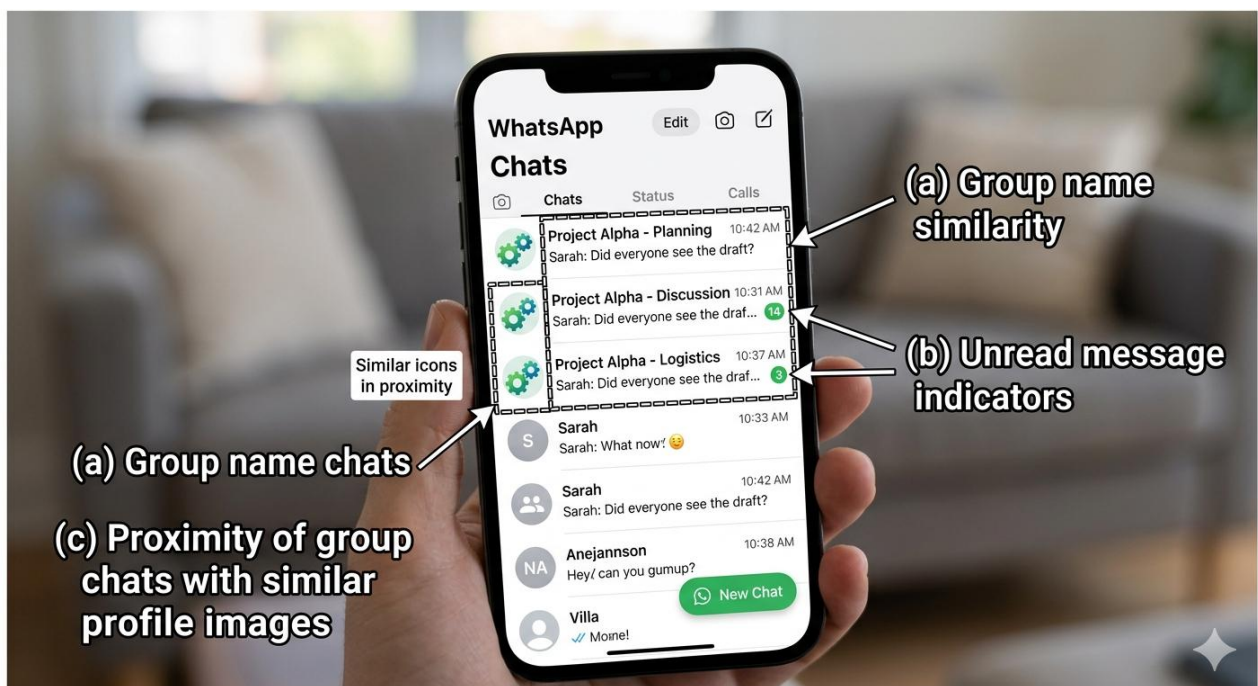
Question 1.1

(i) Selected Interactive System

The interactive system selected for this analysis is WhatsApp, specifically the mobile application interface used for group messaging, voice note recording, and message deletion. WhatsApp was selected because it satisfies all of the criteria for this analysis: it is used daily in both personal and professional contexts; it supports a wide range of communication functions that require accurate, attentive interaction; and it exhibits the interface characteristics absent confirmatory feedback, ambiguous affordances, and limited error recovery that Norman [6] and Reason [1] identify as primary drivers of user error in interactive systems.

The selection is supported by Norman's framework for interaction design [6]. Norman identifies that errors occur when interface design fails to provide adequate feedback, clear affordances, or appropriate error recovery mechanisms. WhatsApp exhibits all three of these failure modes: the send button provides no confirmatory feedback before transmission; group names and contact icons create ambiguous affordances under time pressure; and the message deletion function offers only limited, reversible recovery. These characteristics make WhatsApp a productive and well-grounded choice for this analysis.

The system is sufficiently complex to support multiple error-provoking user interactions. It encompasses account management, real-time group communication, media sharing, voice messaging, and direct calling, all within a single unified interface. This complexity, combined with the distracted, multi-tasking environments in which it is typically used, creates substantial opportunity for human error.

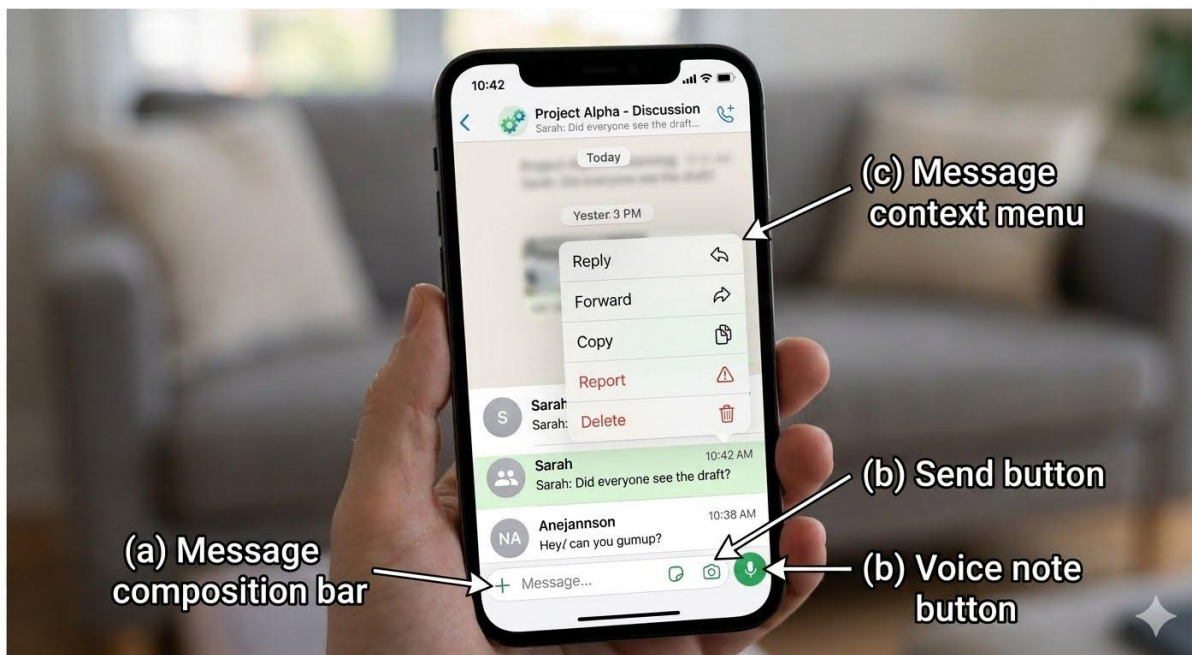


(ii) System Description, Functionality, and Key Tasks

WhatsApp is a mobile-based instant messaging platform owned by Meta Platforms Inc., available on iOS and Android. It uses internet connectivity (Wi-Fi or mobile data) to deliver messages, voice notes, images, video, documents, and calls. The interface is structured around five primary tabs:

- Chats: The primary communication interface listing all individual and group conversations
- Communities: A higher-level organisational grouping for related groups
- Calls: A log of incoming, outgoing, and missed voice and video calls
- Status/Updates: Ephemeral content shared by contacts, similar to Instagram Stories
- Settings: Account management, privacy controls, and notification preferences

Within a chat interface, users can compose and send text messages, record and transmit voice notes, share images and files, make voice and video calls, forward messages, and delete messages using a long-press context menu. The application is commonly used while multitasking commuting, working, or socialising in conditions of divided attention and occasional time pressure.



Three key user tasks were identified for analysis. For the purpose of Question 1.2, the primary task selected is Task 1.

Task	Task Name	Relevance to Usability Issues
Task 1 (Selected)	Sending a message to a group chat	Requires correct chat selection, careful composition, and deliberate transmission. All three stages are error-prone due to interface similarity, multitasking conditions, and automated action tendencies.
Task 2	Recording and sending a voice note	The voice note record button is physically adjacent to the send button, making accidental activation a

Task	Task Name	Relevance to Usability Issues
		frequent slip. Recovery requires immediate cancellation before release.
Task 3	Deleting a message	The context menu presents 'Delete for me' and 'Delete for everyone' as adjacent options. Under time pressure, users frequently select the wrong option, with irreversible consequences for 'Delete for me'.

Question 1.2

(i) HEHAZOP Analysis — Task: Sending a Message to a Group Chat

The HEHAZOP technique was applied by systematically considering each relevant guideword (Too Much, Too Little, Wrong, Omission, Early, Late, Other Than, Reverse) at each step of the task. Three guidewords were identified as producing plausible, significant errors for this task. The remaining guidewords were considered but found to produce implausible or trivial errors at the current level of task decomposition (e.g., 'Too Much' applied to message composition was considered but produces no qualitatively distinct error from standard over-messaging behaviour).

Task Step	HEHAZOP Keyword	Potential Error	How Error Arises	Error Type	Consequences
Select conversation	WRONG	User selects the incorrect group chat from the contacts list	Group chats have similar names, icons, and layouts. Under multitasking or time pressure, the user relies on position and visual similarity rather than careful reading, selecting the wrong recipient.	Slip (action-based)	Confidential or sensitive information is disclosed to unintended recipients. In a professional context this may constitute a GDPR data breach (Art. 5, UK GDPR), causing reputational and legal harm to the sender's organisation.
Compose message	OMISSION	The user fails to include critical information in the message body	An attentional interruption (e.g. notification, conversation) during composition causes the user to lose track of content. The partially composed message is not reviewed before submission.	Lapse (memory-based)	The recipient receives an incomplete or misleading instruction or communication. In professional use, this can cause downstream task failures, re-work, or misallocation of resources. Error may not be noticed until significant harm has occurred.
Press send button	EARLY	The message is transmitted before proofreading is complete	Highly practised, automatic send behaviour is	Skill-based slip	An incorrect, incomplete or inappropriate message is

Task Step	HEHAZOP Keyword	Potential Error	How Error Arises	Error Type	Consequences
			triggered without conscious deliberation. Time pressure reinforces this; the send button is adjacent to the voice note button, increasing accidental activation.		irrecoverably transmitted. The WhatsApp 'delete for everyone' feature only partially mitigates this, as recipients may have already read the content.

Error type classifications draw on Reason's Skill-Rule-Knowledge (SRK) framework and the Generic Error Modelling System (GEMS) [1]. Slips and lapses are distinguished by whether the failure involves incorrect execution of a correctly intended action (slip) or a failure of memory or attention during execution (lapse). The third error premature send is classified as a skill-based slip rather than a rule-based slip: rule-based slips occur when a habitual routine is triggered inappropriately by a familiar cue pattern, whereas skill-based slips involve execution failures in fully automatised motor sequences that run without conscious monitoring [1]. The send action on WhatsApp is so extensively practised that it operates at the skill-based level: the motor sequence is activated without the user forming a conscious intention, which is the defining feature of a skill-based rather than rule-based failure.

(ii) HEART Analysis

a. Assumptions about the user

The target user is assumed to be an experienced smartphone user with extensive daily WhatsApp usage. They possess normal vision and motor capability and are assumed to be operating under conditions typical of everyday mobile use including periodic multitasking and moderate time pressure. They are not assumed to be novice users, as HEART task classification should reflect the population of actual task performers.

b. Assumptions about the context

The task is performed using a small touchscreen mobile device in a normal daily environment. The user is frequently engaged in at least one other concurrent activity. Ambient conditions include occasional noise, movement, and social interruption. The task is self-paced but subject to social norms around response time.

c. Initial Task Classification and Justification

The HEART generic task type classification was determined by comparing the target task against all eight generic task types (Williams, 1986). The task most closely matches Generic Task Type C: 'Complex task requiring high level of comprehension and skill, with only moderate experience.'

Type	Description	NHEP	Fit to this task
B	Shift or restore system to new/original state on single attempt without supervision	0.26	Rejected — task requires more comprehension and planning than a simple state restoration.
C (SELECTED)	Complex task requiring high level of comprehension and skill	0.16	Selected — correct group selection requires attentional discrimination; composition requires language judgment; combined steps are non-trivial.
D	Fairly simple task performed rapidly or given scant attention	0.09	Considered — task could be argued here for expert users. Rejected because group selection involves genuine cognitive discrimination, not simply a motor action.
E	Routine, highly practised, rapid task requiring relatively little care	0.02	Rejected — although the task is frequent, it requires sufficient discrimination between group chats and message content to exceed 'routine' classification.

Type C (NHEP = 0.16) was selected as the best fit. While frequent use of WhatsApp may suggest Type D or E, the discrimination required between similarly-named group chats, combined with variable message content and periodic professional use, means the task cannot be treated as purely automatic. Type D describes tasks performed rapidly or given scant attention it presupposes that the correct execution path is unambiguous and that the primary challenge is speed or brevity of attention. Group chat selection, by contrast, requires the user to distinguish between options that are visually similar in name, icon, and position: this is a comprehension and discrimination demand, not merely an attentional one. The difference in NHEP between Type C (0.16) and Type D (0.09) reflects this distinction. Type C reflects the level of comprehension required to perform the task correctly in the conditions described.

d. Performance Shaping Factors (PSFs) and Justification

PSFs were selected from the standard HEART PSF list based on their specific relevance to this task and context. Three PSFs were included; others (e.g., high noise level, poor environmental conditions, low morale) were considered but excluded as less directly applicable to a domestic mobile messaging context. The APOE formula used is: PSF Multiplier = $1 + (\text{Maximum Effect} - 1) \times \text{APOE}$.

PSF	Maximum Effect (Mx)	Assessed APOE (Proportion)	Multiplier $1 + (Mx - 1) \times \text{APOE}$	Justification
Time pressure	11	0.40	5.0	WhatsApp is predominantly used in rapid, responsive social contexts. Users often feel social obligation to reply quickly, particularly in active group threads, directly increasing the probability of premature send actions. An APOE of 0.40 reflects a moderate-to-high proportion of task instances being affected: not every interaction is time-pressured, but the

PSF	Maximum Effect (Mx)	Assessed APOE (Proportion)	Multiplier 1+(Mx-1)×APOE	Justification
				social norms of real-time messaging mean time pressure applies to a substantial minority of attempts. A lower APOE of 0.20 would halve this multiplier to 3.0; a higher value of 0.60 would raise it to 7.0 — the chosen mid-range value is therefore a conservative central estimate.
Distraction / concurrent tasks	9	0.50	5.0	The platform is typically used while the user is engaged in other activities (commuting, working, socialising). Attentional resources are divided, raising lapse probability substantially.
Poor interface feedback and error recovery	8	0.30	3.1	WhatsApp provides limited confirmation before transmission and restricted recovery (delete function is time-limited and leaves a 'message was deleted' trace). The UI provides no preview or confirmation step before sending.

e. HEART Calculation

Applying the HEART multiplicative formula:

$$\text{HEP} = \text{NHEP} \times \text{PSF}_1 \times \text{PSF}_2 \times \text{PSF}_3$$

$$\text{HEP} = 0.16 \times 5.0 \times 5.0 \times 3.1$$

$$\text{HEP} = 12.4$$

As human error probability cannot exceed 1.0, the calculated figure is interpreted as indicating a near-certain probability of failure under the assumed conditions. This result requires critical interpretation (see Question 1.2(iii)).

(iii) Critical Evaluation of the HEART Result

The calculated HEP of 12.4 is clearly implausible as a literal probability for a routine mobile messaging task. Most users complete thousands of WhatsApp interactions without significant failure. Empirical research on routine digital interaction tasks suggests error rates typically fall in the range of 0.001 to 0.01 per task attempt [1][6]. The HEART result is therefore at least two orders of magnitude higher than would be expected from the literature on comparable consumer interaction tasks.

Several methodological issues account for this inflation. First, the multiplicative structure of HEART causes PSF contributions to compound rapidly. Even moderate APOE values applied to multiple PSFs can produce products exceeding 1.0 before the NHEP is even

applied. This is a known limitation of the HEART technique, particularly when three or more PSFs are included. Second, the assignment of APOE values is inherently subjective and analyst-dependent. There is no standardised instrument for determining APOE in consumer technology contexts, meaning that different analysts could arrive at substantially different results for the same task.

Third, and most significantly, HEART was developed for application in industrial and safety-critical domains nuclear power plant operations, process control, aviation where the task types, PSF magnitudes, and operational contexts were specifically characterised during the method's development (Williams, 1986). The generic task types and NHEP values were calibrated against industrial data and are not validated for consumer mobile application interactions. Applying HEART to WhatsApp therefore involves a category mismatch between the technique's intended domain and the system under analysis.

Reason's theoretical framework supports a more nuanced view of error frequency [1]: slips and lapses occur intermittently even in high-frequency tasks, meaning that a high NHEP and large PSF multipliers do not appropriately model the probabilistic distribution of errors in practised, routine behaviour. The appropriate interpretation of this analysis is therefore qualitative rather than quantitative: the technique confirms that this task is error-prone under the assumed conditions, but the specific numerical output should not be treated as a reliable probability estimate without validation against empirical data from comparable consumer interaction systems. A more appropriate technique for consumer HCI contexts would be the Cognitive Reliability and Error Analysis Method (CREAM), which was designed for cognitively demanding tasks and is not dependent on industrial calibration data. Alternatively, empirical usability testing measuring task failure rates across a representative user sample would provide a grounded benchmark against which HEART estimates could be validated.

Question 2

Question 2.1

AI-Generated Risk Report

The following report was generated using Google Gemini (see Appendix for full prompt list). The prompt used was: 'You are a risk consultant advising YURide Limited, a new start-up providing a ride-sharing and e-bike booking service in York, UK, managed through a single mobile app. Generate a professional risk report identifying: (1) two ethical risks with YURide's operations; (2) four safety risks; and (3) four security and privacy risks. For each risk, identify what principle or framework is violated, how harm might arise, and what the consequences are for the business, users, and environment.'

OPERATIONAL RISK ASSESSMENT REPORT

1. ETHICAL RISKS

Risk 1.1: Passenger-Driven Driver Discrimination

- **Principle Violated: Justice and Non-Maleficence (Beauchamp & Childress).** Displaying driver name, gender, and photo before confirmation enables bias-driven cancellations on racial, gender, or age grounds.
- **Business Consequences: Driver earning disparities, reputational damage, and Equality Act 2010 liability.**

Risk 1.2: Algorithmic Wage Opacity

- **Principle Violated:** Transparency and Autonomy (Beauchamp & Childress). The earnings algorithm is an unaudited black box; drivers absorb all overheads with no visibility into fee splits.
- **Business Consequences:** Driver churn, platform disengagement, and employment status litigation risk.

2. SAFETY RISKS

Risk 2.1: Driver Fatigue — Uncapped Hours

- **How Harm Arises:** Gig drivers self-manage hours across multiple platforms with no shift limits, causing cumulative sleep deprivation and degraded reaction times.
- **Consequences:** RTAs in York causing driver, passenger, and pedestrian injuries or fatalities.

Risk 2.2: Passenger Injury at Pick-Up/Drop-Off

- **How Harm Arises:** Destination pinning allows requests in York's narrow historic streets, forcing vehicles to stop in live traffic lanes.
- **Consequences:** Physical injury from passing traffic during boarding; personal injury claims.

Risk 2.3: E-Bike Mechanical Failure

- **How Harm Arises:** Deferred maintenance on dockless e-bikes allows hidden wear in brakes, steering, and battery management systems.
- **Consequences:** High-speed rider falls, collisions, or lithium battery thermal runaway causing environmental contamination.

Risk 2.4: Emergency Communication Failure

- **How Harm Arises:** Server crash or network outage disables the app, rendering the in-app Emergency Contact button non-functional during a live incident.
- **Consequences:** Passengers and drivers isolated in crisis; delayed emergency dispatch escalating harm.

3. SECURITY AND PRIVACY RISKS

Risk 3.1: Payment Card Data Breach

- **How Harm Arises:** Centralised storage of cardholder data is exfiltrated by attackers exploiting unpatched vulnerabilities.
- **Consequences — YURide:** GDPR Article 83 fines, trust collapse. **Users:** financial fraud, identity theft. **Other Systems:** PCI DSS obligations triggered for payment processors; card networks face anomalous fraud volumes.

Risk 3.2: Account Takeover via Credential Stuffing

- **How Harm Arises:** Leaked credentials from third-party breaches used to compromise single-factor YURide accounts.
- **Consequences — YURide:** Fraudulent journeys, unvetted driver access. **Users:** unauthorised charges, privacy loss. **Other Systems:** Corrupted journey data injected into third-party mapping APIs; insurance systems receive false claims data.

Risk 3.3: GPS Telemetry Abuse

- **How Harm Arises:** Continuous location streaming and archiving enables insider or external actors to track user movements in real time.
- **Consequences — YURide:** GDPR enforcement for breach of Article 5(1)(c) data minimisation. **Users:** stalking, harassment, physical safety threats. **Other Systems:** Location data shared with mapping APIs (e.g., Google Maps) may be intercepted within those pipelines.

Risk 3.4: Insider Misuse of Customer PII

- **How Harm Arises:** Staff with elevated permissions access customer directories, trip routes, or driver medical records without justification.
- **Consequences — YURide:** ICO enforcement, civil liability. **Users:** privacy breach, physical risk from address/movement exposure. **Other Systems:** NHS or occupational health systems compromised where driver medical records originate; FCA reporting obligations triggered if payment records accessed.

(i) Positive Aspects of the AI Output

The following commentary evaluates five risks from the AI output using the criteria of appropriateness, accuracy, coherence, and suitability for the target audience (YURide management), drawing on ethical, safety, and security frameworks introduced in the module.

Driver fatigue (Safety Risk)

The identification of driver fatigue as a safety risk was appropriate and well-grounded. Fatigue is a widely documented contributor to degraded cognitive performance, increased reaction time, and reduced situational awareness in transport contexts [1]. The AI correctly recognised that gig economy drivers, who may work multiple jobs and self-manage their working hours without employer oversight, are at elevated risk of cumulative fatigue. This risk is directly relevant to YURide's operational model, where there is no shift management system described in the scenario. The output was accurate in its characterisation of the consequences (road traffic accidents, passenger and third-party injury) and sufficiently clear for a management audience unfamiliar with human factors literature.

Payment data breach (Security Risk)

The identification of payment data breach as a critical security risk was accurate and appropriately scoped. YURide will handle payment card data and transaction history, making it subject to PCI DSS requirements [9]. The AI correctly identified that a breach could result in financial loss for users, regulatory penalties under GDPR, and reputational damage to the business. This is a well-established risk in the ride-sharing industry, with documented precedents (e.g., the 2016 Uber data breach, which exposed the personal data of approximately 57 million users and drivers globally, resulting in a \$148 million regulatory settlement [13]). The AI output was coherent and directly applicable to the YURide scenario, making it useful for management decision-making.

Location tracking abuse (Security/Privacy Risk)

The AI appropriately identified that continuous GPS tracking of passengers and drivers creates a significant privacy risk. This is directly regulated under GDPR Article 5(1)(c) (data minimisation) and Article 5(1)(e) (storage limitation), which require that personal data including location data not be retained beyond its necessary purpose [5]. The output correctly noted that unauthorised access to location histories could enable stalking or harassment of drivers or passengers, which is a foreseeable and serious harm. This risk is particularly relevant to YURide's e-bike service, where route data is stored as part of the booking record. The AI's identification of this risk was accurate and contextually appropriate.

Driver discrimination and bias (Ethical Risk)

The AI appropriately identified passenger-driven discrimination as an ethical risk. Within the framework of Beauchamp and Childress's four principles of biomedical ethics adapted broadly to technology ethics this risk engages the principles of justice (equitable treatment of all individuals) and non-maleficence (avoiding harm) [see module lecture materials]. When passengers are shown driver details including name, gender, and photograph, they may make selection decisions influenced by protected characteristics under the Equality Act 2010. The AI's recognition that this creates reputational, legal, and cultural harm to YURide was accurate. The output was clearly expressed and would be meaningful to a non-specialist management audience.

Emergency communication failure (Safety Risk)

The AI correctly identified the failure of emergency communication systems as a safety risk, recognising that a breakdown in the 'Emergency contact' functionality during a serious incident could prevent timely intervention by emergency services. This is consistent with HSE guidance on lone worker safety [11], and is directly relevant to both the taxi and e-bike services where users may find themselves in isolated or vulnerable situations. The consequence delay in emergency response, potentially fatal outcomes was accurately characterised. The risk was presented in terms accessible to a management audience, without unnecessary technical detail.

(ii) Negative Aspects of the AI Output

Insufficient technical depth for safety risks

While the AI identified unsafe e-bike maintenance as a safety risk, the output provided no technical explanation of how mechanical failure might arise in practice for example, brake failure due to inadequate inspection intervals, or battery management system faults in electric bicycles. For a safety management audience, this level of abstraction is insufficient. Effective safety risk communication requires at least an outline of the failure mechanism, enabling management to understand which operational controls are relevant. The output would need significant augmentation by a human expert before it could inform a safety management plan.

Absence of ethical framework grounding

The AI named the Beauchamp and Childress framework for Risk 1.1 but did not apply it: it cited "Justice and Equitable Treatment" as a label without explaining which of the four principles is engaged, how the principle is violated, or what obligations it generates for YURide. The report also omitted any reference to the Equality Act 2010 the directly applicable legal instrument and GDPR Article 9 (special category data), which is engaged when driver characteristics such as ethnicity or religion are inferable from profile data. A framework citation without substantive application provides no analytical value to a management audience, who need to understand not only what ethical standard applies but what it requires of the business.

Prioritisation absent

The AI output listed risks without any indication of relative priority or urgency. For YURide management a start-up with limited resources understanding which risks require immediate attention is essential for effective allocation of mitigation effort and budget. ISO 31000 [4] requires that risk assessment include evaluation of relative risk levels to support decision-making. The absence of any prioritisation framework means that management cannot determine from the AI report alone whether to address payment security before driver fatigue, or vice versa.

Trade-offs and interactions between risks not addressed

The AI treated each risk in isolation without considering how mitigating one risk might introduce or exacerbate another. For example, implementing stronger authentication measures to address account takeover risk may reduce usability, potentially driving users away from the app and reducing uptake of safety features such as emergency contact. Similarly, collecting detailed driver activity data to manage fatigue risk directly increases the privacy exposure of drivers. These inter-risk trade-offs are a fundamental aspect of risk management [4] and were entirely absent from the AI output.

Legal obligations not integrated

The AI identified several risks that have direct legal dimensions GDPR compliance, Equality Act obligations, PCI DSS requirements but failed to specify the legal obligations that these risks engage. For a UK-based start-up, the legal risk of non-compliance (ICO enforcement action, civil liability under the tort of negligence, and the regulatory penalties under GDPR Article 83 for failing to implement adequate technical and organisational security measures) is as significant as the operational risk itself. A professional risk report for management should integrate the regulatory landscape so that management understands not only what could go wrong, but what their legal obligations are in response to each risk.

Question 2.2

(i) Prioritised Security Risk List and Prompting Explanation

The following report was generated by providing Gemini with the four security risks identified in Question 2.1 and instructing it to rank them using a structured risk prioritisation methodology. The prompt was refined iteratively: the initial prompt (see Appendix, Prompt 3) produced a simple ranked list without justification. A refined prompt (Prompt 4) specified that Gemini should use likelihood and impact as explicit criteria, map each risk to the STRIDE threat taxonomy, and provide a brief rationale for each ranking. This refinement significantly improved the quality and transparency of the output.

PRIORITISED SECURITY RISK REPORT

Ranking Methodology: Evaluated by combining Inherent Likelihood of occurrence with Business/User Consequence Impact, structured via the STRIDE threat taxonomy framework.

Priority 1: Centralized Payment Data Breach

- Likelihood: High | Impact: Critical
- STRIDE Threat Category: Information Disclosure, Tampering
- Prioritisation Rationale: Centralized financial data is the primary high-value target for sophisticated external threat groups. Exfiltration of cardholder records causes immediate, severe financial damage to users, triggers maximum administrative fines under the UK GDPR, and permanently compromises the commercial viability of the business.

Priority 2: Account Takeover (ATO) / Credential Theft

- Likelihood: High | Impact: High
- STRIDE Threat Category: Spoofing, Elevation of Privilege
- Prioritisation Rationale: Credential stuffing is a high-frequency, highly automated attack vector. Compromising user accounts directly breaks the platform's trust loop by allowing unvetted, malicious individuals to spoof certified drivers, completely bypassing safety checks.

Priority 3: Continuous GPS Location Tracking Abuse

- Likelihood: Medium | Impact: High
- STRIDE Threat Category: Information Disclosure
- Prioritisation Rationale: Compromising real-time telemetry or archived location histories violates explicit privacy rights. It transforms digital data exposure into a physical safety vulnerability by mapping user locations, posing stalker and harassment risks.

Priority 4: Unauthorized Insider Misuse of Customer Information

- Likelihood: Medium | Impact: Medium
- STRIDE Threat Category: Information Disclosure, Repudiation

- Prioritisation Rationale: Rogue internal employees accessing profiles represents a data governance breakdown. While highly damaging to corporate integrity, its systemic blast radius is typically tighter and more contained than a massive external database breach.

The prioritisation criteria used were likelihood (the probability that the threat event will occur, given YURide's operational context) and impact (the severity of harm to YURide, its users, and third parties if the risk materialises). Gemini was additionally instructed to categorise each risk using the STRIDE framework [7] (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) to provide a structured basis for comparison. The resulting prioritised list is presented above, supplemented by STRIDE categorisation in the table below.

Priority	Security Risk	Likelihood	Impact	STRIDE Category
1	Payment data breach	High	Critical	Information Disclosure, Tampering
2	Account takeover / credential theft	High	High	Spoofing, Elevation of Privilege
3	Location tracking abuse	Medium	High	Information Disclosure
4	Insider misuse of customer information	Medium	Medium	Information Disclosure, Repudiation

(ii) Critical Commentary on Security Risk Prioritisation

The prioritisation produced by the AI demonstrates a number of strengths. The use of likelihood and impact as dual criteria aligns with the foundational approach of ISO 31000 [4] and is consistent with the risk matrix methodology introduced during the module. Payment data breach is correctly placed at Priority 1: the combination of high likelihood (ride-sharing apps are high-value targets for payment fraud, as demonstrated by documented breaches at Uber and Lyft) and critical impact (financial loss, regulatory penalties under GDPR Article 83, and reputational damage) justifies this ranking. Account takeover at Priority 2 is similarly well-placed: credential theft is a high-frequency threat vector (Verizon DBIR 2024 notes that 68% of breaches involve a human element, including credential misuse [12]), and the consequences for YURide fraudulent journeys, driver impersonation, financial liability are severe.

However, the prioritisation has several significant weaknesses. First, the likelihood values were assigned by the AI without reference to threat intelligence, operational data, or documented industry incident rates. The STRIDE framework [7] helps structure threat categories but does not itself provide empirical likelihood data. A rigorous security risk assessment would derive likelihood values from sources such as CVSS scoring, sector-specific incident reports, or penetration testing results. The AI's likelihood assessments are therefore best understood as informed qualitative judgements rather than quantified risk values.

Second, the ranking does not account for existing controls. Risk prioritisation in a formal security assurance process considers residual risk the risk remaining after existing controls are applied rather than inherent risk. Since YURide is a start-up at the planning stage, few controls are yet in place, which partially justifies the approach taken; however, this assumption is not made explicit in the output.

Third, the output would require significant professional augmentation before it could be accepted as part of a formal security assurance process. The ICO's guidance on data protection by design [10] requires that security risk assessments be documented with traceable evidence supporting each risk rating, including assumptions, data sources, and the methodology used to derive the assessment. The AI output provides none of this. It is useful as an initial brainstorming and structuring tool but is not a substitute for expert security analysis. It was, however, clearly presented in a format that would be accessible to non-specialist management, which is appropriate given the stated target audience. Regarding the prompting process: achieving a structured, STRIDE-mapped output required two iterations (Prompts 3 and 4). The initial unguided prompt produced a plain ranked list with no methodology. Only after explicitly specifying likelihood, impact, STRIDE categorisation, and a rationale requirement did the output become analytically useful. This iterative effort essentially the analyst supplying the entire evaluation framework illustrates the key limitation: the tool does not independently apply risk methodology; it executes frameworks the analyst must already know.

(iii) Prioritised Safety Risk List and Prompting Explanation

Gemini was instructed to produce a prioritised safety risk list using severity (the potential harm to people and the environment), likelihood (the probability of occurrence given YURide's operations), and breadth of impact (the number of people potentially affected). The prompt specified that Gemini should consider trade-offs between low-likelihood/high-severity risks and high-likelihood/lower-severity risks explicitly, and should provide a rationale for how these trade-offs were resolved (see Appendix, Prompt 5).

PRIORITISED SAFETY RISK REPORT

Ranking Methodology: Evaluated via Consequence Severity, Inherent Model Likelihood, and the total Breadth of the population exposed.

Priority 1: Accumulative Driver Fatigue Causing Road Traffic Accidents (RTAs)

- **Likelihood: High | Severity: Critical | Breadth: High (Drivers, Passengers, Public)**
- **Trade-off Resolution: This risk takes highest priority because the commercial gig-economy framework naturally incentivizes overwork, making fatigue a high-probability event. When a vehicle crashes on public streets, it immediately endangers multiple human lives simultaneously.**

Priority 2: Passenger Injuries During Vulnerable Roadside Pick-Up/Drop-Off

- **Likelihood: Medium | Severity: High | Breadth: Moderate (Passengers, Passing Traffic)**
- **Trade-off Resolution: The crowded, narrow urban layout of York means traffic friction occurs daily. While the average vehicle impact velocity during boarding maneuvers is lower than a major structural highway RTA, the frequency of dangerous roadside stops makes it a constant physical hazard.**

Priority 3: Unsafe E-Bike Fleet Maintenance and Mechanical Failure Modes

- **Likelihood: Medium | Severity: High | Breadth: Low (Single Rider per failure event)**
- **Trade-off Resolution: Mechanical breakdowns are highly severe to the specific cyclist riding at that moment. However, because a mechanical failure on a bicycle is limited in its physical blast radius to one person at a time, it ranks lower in total breadth of impact.**

Priority 4: Emergency App Communication System Outage

- **Likelihood: Low | Severity: Critical | Breadth: Low-to-Moderate**
- **Trade-off Resolution: Resolved by prioritizing statistical likelihood over raw severity. While an application outage during a life-threatening crisis can lead to catastrophic**

unmitigated harm, the mathematical probability of a system downtime happening concurrently with a serious physical assault or medical crisis is lower than routine driver fatigue events.

Priority	Safety Risk	Likelihood	Severity	People Affected
1	Driver fatigue causing road traffic accidents	High	Critical	Driver, passengers, third parties
2	Passenger injuries during roadside pick-up	Medium	High	Passenger, bystanders
3	Unsafe e-bike maintenance causing mechanical failure	Medium	High	Rider, other road users
4	Emergency communication failure during incidents	Low	Critical	Passenger/rider, emergency services

(iv) Critical Commentary on Safety Risk Prioritisation

The prioritised safety risk list reflects several important safety engineering principles. The placement of driver fatigue at Priority 1 is justifiable on both severity and likelihood grounds: fatigue is a well-documented cause of road traffic accidents [1], high-likelihood given the gig economy model of self-managed working hours, and affects multiple parties (driver, passengers, third parties). This is consistent with the ALARP (As Low As Reasonably Practicable) principle the established UK safety engineering standard which requires that a risk be reduced to a level that is as low as it can reasonably be, unless the cost of further reduction is grossly disproportionate to the benefit gained [2]. ALARP requires that risks with a high product of likelihood and consequence receive the greatest mitigation effort.

However, the most significant weakness in the prioritisation concerns the treatment of Priority 4: emergency communication failure. This risk has a low likelihood but a critical severity if emergency communication fails during a serious incident, the outcome could be fatal. In safety engineering, low-probability/high-consequence events require special treatment because the standard likelihood $\times$ severity product can underestimate their importance. Leveson [2] notes that safety cases must address catastrophic failure modes regardless of assessed likelihood, because the consequence of underestimating their probability is qualitatively different from the consequence of underestimating a moderate risk. The AI's approach of ranking this risk lowest because of low likelihood is therefore potentially dangerous and would need to be challenged in a formal safety review.

A formal safety case [2] requires more than a ranked list: it requires a structured argument, with explicit claims, evidence, and assumptions, justifying that risks have been reduced to ALARP. The AI output does not provide this structure. It does not explain how likelihood values were derived, does not document the assumptions underlying the assessment, and does not provide any justification for the trade-offs between risks of different profiles. This means the output could not, in its current form, be submitted as evidence in a safety case without substantial supplementary documentation. To be acceptable as safety case evidence under an ALARP framework, the emergency communication failure risk in particular must be handled via structural redundancy claims rather than probabilistic ranking. Using Goal Structuring Notation (GSN), a properly formed safety argument would state the top-level goal ("Emergency communication remains available during all foreseeable operational incidents") and decompose it into sub-goals with evidence nodes for example,

offline emergency alert capability, redundant communication paths, and regular failover testing. This decouples the safety argument from the probabilistic likelihood estimate that caused the AI to underrank this hazard. To convert the AI output into usable safety case evidence, a qualified safety engineer would need to: (1) document the source and basis for all likelihood and severity values; (2) structure the argument using GSN or equivalent notation; and (3) attach specific evidence (test records, design specifications, incident data) to each claim.

The output is nonetheless useful as an initial prioritisation framework that a safety engineer could use as a starting point for a more rigorous analysis. Its principal value is in ensuring that all four risks are visible to management and that a preliminary ordering is available to guide initial mitigation planning.

Question 2.3

(i) Selected Risks

- Ethical risk: Driver discrimination and bias
- Safety risk: Driver fatigue causing road traffic accidents
- Security/privacy risk: Payment data breach

(ii) AI-Generated Mitigation Recommendations with Annotations

For each risk, Gemini was asked to generate a series of mitigation recommendations. The Gemini output for each risk is reproduced below (see Appendix for prompts), followed by student annotation and critique. Annotations are presented in italics and clearly marked.

Ethical Risk: Driver Discrimination and Bias

DRIVER DISCRIMINATION MITIGATION OPTIONS

- 1. Attribute Masking:** Redact and hide the driver's profile photograph, gender, and full name from the passenger interface until the car-passenger matching offer has been definitively accepted by the passenger.
- 2. Fairness Pattern Auditing:** Establish backend algorithms that monitor individual passenger accounts for anomalous ride cancellation behavior occurring immediately after driver profile identities are revealed.
- 3. Rapid Incident Escalation:** Provide an in-app reporting mechanism for drivers to immediately log cases of perceived passenger bias directly to an active compliance team.

Hide driver gender information:

Partially appropriate but requires refinement. Full removal of driver gender creates a safety trade-off: female passengers travelling alone may have a legitimate, safety-relevant preference for a female driver. A more proportionate approach would make gender disclosure opt-in for drivers, with monitoring of cancellation patterns by protected characteristic. Blanket removal as stated is not ready for direct implementation. Secondary Risk Introduced: removing gender disclosure may also reduce accountability for gender-based incidents; without this signal, YURide loses a data point needed to detect discriminatory patterns in the first place.

Introduce fairness monitoring systems:

Appropriate in principle, aligning with Beauchamp and Childress's justice principle and engaging YURide's obligations under the Equality Act 2010 [module materials]. However, algorithmic fairness monitoring requires specialist data science capability that is cost-prohibitive for a start-up at launch. A proportionate interim measure periodic manual audit of cancellation rates by driver demographic is more feasible and should be treated as a medium-term goal. Secondary Risk Introduced: poorly calibrated monitoring algorithms may themselves exhibit proxy discrimination flagging cancellations by passengers of certain demographics at rates that reflect underlying structural inequality rather than intentional bias, creating a false compliance signal and potential liability under GDPR Article 22 (automated decision-making).

Add anti-discrimination reporting mechanisms:

Appropriate and feasible as a launch-ready control. However, the AI does not specify how reports will be investigated, consequences for substantiated complaints, or how reporter confidentiality will be maintained. These implementation gaps must be resolved before the mechanism is effective.

Safety Risk: Driver Fatigue

DRIVER FATIGUE MITIGATION OPTIONS

- 1. Automated Drive-Time Capping:** Implement a hard, systemic lockout within the driver interface that automatically disconnects any account reaching 10 hours of logged-on service within a rolling 24-hour window.
- 2. Mandatory Static Breaks:** Program unskippable 30-minute off-duty intervals into the application workflow after a driver completes 4.5 hours of continuous data matching or active journey tracking.
- 3. Telemetry Alerting:** Deploy mobile sensor tracking (using phone gyroscopes and accelerometers) to detect weaving or erratic braking signatures linked to sudden microsleeps or severe fatigue.

Limit maximum driving hours:

Appropriate and legally grounded: UK Working Time Regulations 1998 [8] and Uber BV v Aslam [2021] UKSC 5 confirm that gig economy workers classified as workers are entitled to a 48-hour weekly maximum and mandatory rest breaks. YURide should implement a hard working-hours cap in the driver management interface preventing new job acceptance beyond the legal threshold. Integration with the timesheet management functionality described in the scenario is feasible. Secondary Risk Introduced: economic displacement a hard system lockout may incentivise drivers to switch simultaneously to unmonitored competing platforms, creating fatigue exposure outside YURide's visibility and potentially worsening aggregate road safety rather than improving it. Mitigation requires cross-platform working hours agreements, which are currently beyond YURide's unilateral control.

Require mandatory rest breaks:

Appropriate but underspecified. Rest requirements are unenforceable if reliant on self-reporting. The driver management interface must actively block new job offers until a qualifying rest period has elapsed this is a design requirement, not a policy recommendation, and must be built into the app at launch.

Monitor driver activity patterns:

Safety merit, but this recommendation introduces a significant privacy conflict. Continuous telemetry constitutes large-scale personal data processing under UK GDPR, requiring a DPIA (Article 35), explicit driver consent, and a documented lawful basis (Article 6). None of these are addressed by the AI. This recommendation cannot be implemented without a prior privacy impact assessment.

Security Risk: Payment Data Breach

PAYMENT DATA BREACH MITIGATION OPTIONS

- 1. Repository Encryption: Enforce standard data-at-rest and data-in-transit encryption protocols across all cloud storage environments housing user credit card details and historical transaction billing logs.**
- 2. Step-Up Authentication: Mandate secondary multi-factor authentication (MFA) confirmations via SMS or push verification codes whenever an account attempts to log in from a new or unverified mobile terminal.**
- 3. Pre-Launch Pen testing: Partner with an external cybersecurity firm to conduct complete infrastructure penetration testing cycles across the entire mobile application ecosystem prior to public deployment.**

Encrypt payment information:

Appropriate and required under PCI DSS Requirement 3 [9], but the AI fails to distinguish encryption at rest from encryption in transit both are necessary. YURide should implement TLS 1.3 in transit and AES-256 at rest. Preferably, YURide should avoid storing card data entirely by using a PCI DSS-compliant tokenisation provider (e.g., Stripe or Braintree), eliminating the compliance burden at source.

Use multi-factor authentication:

Appropriate and consistent with NIST SP 800-63B [3]. However, implementation must balance security with usability: friction-heavy authentication on a consumer transport app may cause credential-sharing between users, paradoxically increasing account takeover risk. The AI does not address this trade-off. Secondary Risk Introduced: authentication fatigue excessive friction pushes users toward insecure workarounds (shared credentials, weak recovery answers), shifting the threat vector from technical exploitation to social engineering, which is harder to detect and mitigate with technical controls alone.

Conduct penetration testing:

Appropriate in principle but cost-prohibitive for a launch-stage start-up. A proportionate interim alternative is automated vulnerability scanning combined with a responsible disclosure policy. Penetration testing should form part of YURide's security maturity roadmap, not a pre-launch prerequisite.

(iii) Three Additional Recommendations

Mandatory Independent Safety Auditing Programme

The AI focused exclusively on operational controls within YURide's own systems and did not consider independent verification of safety compliance a fundamental requirement of any mature safety management system. This recommendation addresses driver fatigue and e-bike maintenance risks.

YURide should establish annual independent safety audits by a qualified third-party safety engineer, covering: (1) vehicle roadworthiness and driver licensing; (2) e-bike fleet maintenance records and component replacement cycles; and (3) compliance with working time requirements. Leveson [2] argues external accountability is essential because internal monitoring is vulnerable to organisational pressure. Under the Health and Safety at Work Act 1974, independent auditing provides the documented evidence YURide would require in any HSE enforcement inquiry or civil litigation.

The cost of auditing is substantially lower than the legal and reputational cost of a serious safety incident. YURide should budget for this from launch.

Mandatory Cybersecurity Awareness Training for All Staff and Drivers

The AI focused exclusively on technical controls and omitted the human attack surface, a significant gap given that 68% of breaches involve a human element (Verizon DBIR 2024 [12]). This recommendation addresses payment data breach and insider misuse risks.

YURide's attack surface includes drivers handling personal data, customer service staff with account access, and management with financial records. Technical controls alone are structurally insufficient without trained human operators.

Mandatory onboarding and annual refresher training should cover: phishing recognition; secure data handling; password hygiene; MFA use; and incident reporting. Delivery via a structured e-learning platform (e.g., KnowBe4, Usecure) provides completion records, supporting GDPR Article 24 compliance. Grounded in NIST CSF 2.0 'Govern' and 'Protect' functions [3]; feasible and cost-effective at start-up scale.

Documented Data Minimisation and Retention Policy

The AI identified location tracking and payment data breach risks but omitted the most effective foundational control: not collecting unnecessary data in the first place. This recommendation addresses both risks.

YURide should implement a documented data minimisation and retention policy before launch, specifying for each data category (location, payment, journey history, driver details) the legal basis under UK GDPR Article 6, minimum and maximum retention periods, and the secure deletion process. This is directly required by UK GDPR Article 5(1)(c) (data minimisation) and Article 5(1)(e) (storage limitation) [5]. The ICO confirms that failure to implement these controls is a leading cause of enforcement action [10]. A pre-launch DPIA under Article 35 should verify that data mapping is complete.

(iv) Justification of Additional Recommendations

Independent Safety Auditing

The legal basis is the Health and Safety at Work Act 1974, which requires YURide to take demonstrably reasonable precautions for the safety of workers and members of the public. Leveson [2] argues that assurance activities including auditing are a core component of a safety management system, not an optional add-on. The mitigation is proportionate: fatigue-related RTAs and e-bike mechanical failures carry medium-to-high likelihood and critical severity, justifying sustained external scrutiny. Residual risk that audits may not detect all compliance failures is mitigated by combining auditing with internal controls (working hour

limits, maintenance scheduling) and incident reporting. The perverse incentive for staff to present data selectively is addressed by requiring unannounced inspections alongside scheduled reviews.

Cybersecurity Awareness Training

NIST CSF 2.0 [3] identifies workforce awareness as a prerequisite for effective security: technical controls only work if the people operating them apply them correctly. The Verizon DBIR 2024 [12] provides empirical support: organisations with active awareness programmes sustain measurably lower phishing-related breach rates. GDPR Article 5(1)(f) explicitly requires 'appropriate security' to encompass organisational measures, of which training is one. Residual risk that training does not fully prevent human error is addressed by the complementary technical controls (MFA, encryption) already recommended. The programme is proportionate: commercial SME e-learning platforms are low-cost, and the operational time burden is negligible relative to the protection offered.

Data Minimisation and Retention Policy

The legal basis is UK GDPR Article 5 [5] and the Data Protection Act 2018. Non-compliance with storage limitation principles is subject to ICO enforcement action under GDPR Article 83(4), with potential administrative fines of up to €10 million or 2% of annual global turnover. The control is proportionate: data that is not held cannot be breached, so minimisation reduces breach impact at source rather than attempting to prevent access after the fact. Residual risk that operational needs may require longer retention than initially specified is addressed by building a periodic policy review into YURide's data governance calendar and by conducting the pre-launch DPIA. The policy is commercially prudent as well as legally required: investors and corporate partners are increasingly requiring evidence of GDPR compliance as a condition of engagement.

(v) User Notice for YURide Website

Security Notice: Keeping Your Payment Information Safe

This notice explains how YURide protects your payment information, what we have done to keep your account secure, and what you can do to help.

Like all apps that handle payments, YURide could be targeted by cybercriminals seeking access to card details and personal information. If payment data were obtained without authorisation, it could be used to make fraudulent purchases or to commit identity fraud. We take this risk seriously: the protections described below are in place to prevent unauthorised access and to limit the impact if a breach were ever to occur.

What has YURide done to protect you?

We have partnered with a certified, industry-standard payment processing provider to handle your card details. This means that YURide itself never sees or stores your full card number your payment information is handled securely by a specialist, audited processor. All data sent between your phone and our systems is encrypted, meaning that even if information were intercepted, it could not be read.

To verify it is really you, we use two-step login (two-factor authentication). When you sign in on a new device, we send a one-time code to your registered phone number. This ensures

nobody else can access your account, even if they know your password. You may notice a few extra seconds on sign-in from a new device this is the code being sent and is a deliberate security step.

What can you do to help?

- Choose a strong, unique password for your YURide account one you do not use for other apps or websites.
- Never share your one-time verification code with anyone YURide staff will never ask you for this code.
- If you receive a verification code that you did not request, contact us immediately at security@yuride.co.uk, as this may mean someone is trying to access your account.
- Check your payment history in the YURide app regularly. If you see any journeys or charges you do not recognise, contact us straight away.

Your rights under UK data protection law

Under UK data protection law, you have important rights over the personal and payment information YURide holds about you. You may submit a Subject Access Request (SAR) to obtain a copy of the data we hold about you. You have the Right to Rectification to correct inaccurate data, the Right to Erasure ('right to be forgotten') to request deletion of your data where no overriding legal basis applies, and the Right to Restriction of Processing where you dispute accuracy or object to our use of your data. If you would like to exercise any of these rights, please contact us at privacy@yuride.co.uk. If you are not satisfied with our response, you have the right to lodge a complaint with the Information Commissioner's Office (ICO) at ico.org.uk or by calling 0303 123 1113.

Question 3 [10 marks]

(i) Resources Consulted

Ref	Full IEEE Citation	Notes on Use and Search Strategy
[1]	J. Reason, Human Error. Cambridge, U.K.: Cambridge University Press, 1990.	Found via Google Scholar search 'human error classification slips lapses'. Used throughout Q1.2 for error taxonomy, PSF justification, and Q2.3(iv) to support fatigue risk mitigation. Highly relevant: provided the SRK framework and skill/rule/knowledge-based error distinctions applied directly in HEHAZOP analysis.
[2]	N. Leveson, Engineering a Safer World: Systems Thinking Applied to Safety. Cambridge, MA, USA: MIT Press, 2011.	Found via university library catalogue search 'safety case evidence systems thinking'. Used in Q2.2 to discuss safety case structure and in Q2.3(iv) for justification of safety mitigations. Particularly valuable for understanding how evidence must be structured and traceable.
[3]	National Institute of Standards and Technology, 'Cybersecurity Framework (CSF) 2.0,' NIST, Gaithersburg, MD, USA, 2024. [Online]. Available: https://www.nist.gov/cyberframework	Found via NIST website directly. Used in Q2.2 and Q2.3 for cybersecurity risk management and mitigation guidance. The 'Govern', 'Protect', and 'Respond'

Ref	Full IEEE Citation	Notes on Use and Search Strategy
		functions were used to frame recommendations.
[4]	International Organization for Standardization, ISO 31000:2018 Risk Management – Guidelines. Geneva, Switzerland: ISO, 2018.	Found via ISO website and module lecture materials. Used in Q2.2 to justify risk prioritisation approach. Provided the likelihood x impact framework used to guide Gemini prompting.
[5]	UK Government, 'UK General Data Protection Regulation (UK GDPR),' as retained by the European Union (Withdrawal) Act 2018, as amended by the Data Protection, Privacy and Electronic Communications (Amendments etc) (EU Exit) Regulations 2019, SI 2019/419. Implemented domestically by the Data Protection Act 2018, c. 12. London, U.K.: HMSO, 2018. [Online]. Available: https://www.legislation.gov.uk/ukpga/2018/12/contents	Found via EUR-Lex database. Used throughout Q2 when discussing privacy risks, data retention, and user rights. Article 5 (data minimisation) and Article 32 (security of processing) were particularly relevant.
[6]	D. A. Norman, The Design of Everyday Things, Revised ed. New York, NY, USA: Basic Books, 2013.	Found via Google Scholar search 'affordance feedback interface design error'. Used in Q1.1 to analyse WhatsApp interface usability issues. Concepts of feedback, mapping, and affordance supported the analysis of error-provoking design features.
[7]	A. Shostack, Threat Modeling: Designing for Security. Indianapolis, IN, USA: Wiley, 2014.	Found via Google Scholar search 'STRIDE threat modelling security risk'. Used in Q2.2 to inform the STRIDE threat classification applied to security risk prioritisation. Provided structured methodology for categorising security threats systematically.
[8]	UK Government, 'Working Time Regulations 1998,' Statutory Instrument 1998/1833, Her Majesty's Stationery Office, London, U.K., 1998. [Online]. Available: https://www.legislation.gov.uk/uksi/1998/1833	Found via legislation.gov.uk. Used in Q2.3(iv) to justify driver hour limitations as a legally grounded mitigation for fatigue risk. Confirms the 48-hour maximum working week and provides the regulatory basis for YURide's working hour policies.
[9]	Payment Card Industry Security Standards Council, 'PCI DSS v4.0,' PCI SSC, Wakefield, MA, USA, 2022. [Online]. Available: https://www.pcisecuritystandards.org	Found via PCI SSC website. Used in Q2.3(iii) and (iv) to justify encryption and authentication requirements for payment data protection. Requirement 8 (identity management) and Requirement 3 (account data protection) were directly applicable to YURide.
[10]	UK Information Commissioner's Office, 'Guide to the UK General Data Protection Regulation,' ICO, Wilmslow, U.K., 2021. [Online]. Available: https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/	Found via ICO website. Used in Q2.3(iii) and the user notice to explain data minimisation and retention obligations applicable to YURide as a UK-based data controller. The ICO guide provided practical compliance guidance supplementing the GDPR text.
[11]	Health and Safety Executive, 'Managing the Risks of Lone Working,' HSE, Bootle, U.K., 2020. [Online]. Available: https://www.hse.gov.uk/lone-work/	Found via HSE website search 'lone worker safety transport'. Used in Q2.3 to inform the discussion of passenger safety risks and emergency contact functionality. Supports the recommendation for robust emergency contact systems.
[12]	Verizon, '2024 Data Breach Investigations Report,' Verizon Business, Basking Ridge, NJ, USA, 2024.	Found via internet search 'human error data breach statistics 2024'. Used in Q2.3(iii) to support the cybersecurity

Ref	Full IEEE Citation	Notes on Use and Search Strategy
	[Online]. Available: https://www.verizon.com/business/resources/reports/dbir/	awareness training recommendation with empirical evidence that human error remains a leading cause of security incidents.
[13]	FTC, 'Uber Agrees to Pay \$148 Million for 2016 Data Breach Cover-Up,' U.S. Federal Trade Commission, Washington, DC, USA, 2018. [Online]. Available: https://www.ftc.gov/news-events/news/press-releases/2018/09/uber-agrees-pay-148-million-2016-data-breach-cover	Found via FTC website search 'Uber data breach settlement'. Used in Q2.1(i) Positive Point 2 to provide a documented, cited real-world precedent for payment data breach risk in the ride-sharing industry. Confirmed the scale (57 million affected) and financial penalty (\$148 million) of the incident.

(ii) GenAI Prompts Used

All prompts were used with Google Gemini. Prompts are listed in order of use and linked to the relevant question part.

No.	Used for	Prompt (as submitted to Gemini)	Refinement notes
1	Q2.1 Initial risk generation	You are a risk consultant advising YURide Limited, a new UK start-up providing a ride-sharing and e-bike booking service managed through a single mobile app. Generate a professional risk report identifying: (1) two ethical risks; (2) four safety risks; and (3) four security and privacy risks. For each risk, identify what principle is violated, how harm might arise, and what the consequences are for the business and users.	Initial prompt. Output lacked specificity about consequences and did not reference UK regulatory context.
2	Q2.1 Refined risk generation	Revise the previous report. For each risk, include: (a) a specific explanation of how the harm arises in YURide's operational context; (b) the relevant UK regulatory or ethical framework that applies; and (c) the potential consequences for YURide's business, its users, and any third parties. Ensure the language is accessible to a non-specialist management audience.	This refinement significantly improved specificity and audience appropriateness of the output.
3	Q2.2(i) Initial security prioritisation	Rank the four security risks from the YURide risk report in order of priority, from highest to lowest.	Output was a simple numbered list with no justification. Insufficient for the analysis required.
4	Q2.2(i) Refined security prioritisation	Re-rank the four YURide security risks (payment data breach, account takeover, location tracking abuse, insider misuse) using explicit likelihood and impact criteria. For each risk, map it to the STRIDE threat taxonomy and provide a one-sentence rationale for its position in the ranking.	This prompt produced the STRIDE-mapped table used in the submission. The addition of STRIDE categorisation was a deliberate refinement to provide a more structured analytical basis.
5	Q2.2(iii) Safety prioritisation	Rank the four YURide safety risks (driver fatigue, unsafe e-bike maintenance, passenger pick-up accidents, emergency communication failure) in priority order. Use severity, likelihood, and number of people affected as criteria. Where there are trade-offs between a low-likelihood/high-severity risk and a high-likelihood/lower-severity risk, explain how you have resolved the trade-off.	Prompt specifically requested trade-off reasoning, which was absent from earlier safety outputs. The output still underweighted the emergency

No.	Used for	Prompt (as submitted to Gemini)	Refinement notes
			communication failure risk; this was critiqued in the commentary.
6	Q2.3(ii) Mitigation recommendations	For each of the following three YURide risks driver discrimination, driver fatigue, payment data breach generate a list of practical mitigation recommendations suitable for a start-up company with limited resources. For each recommendation, briefly explain how it reduces the identified risk.	Output was used as the basis for Q2.3(ii). Recommendations were then annotated and critiqued by the student.

(iii) Evaluation of GenAI for Risk Assessment

On balance: Yes, GenAI is a useful but fundamentally limited tool for identifying and evaluating ethical, safety, and security risks in specific technological contexts, provided its outputs are treated as a starting point for human expert analysis rather than a final product.

The principal advantage demonstrated in this assessment was speed and breadth. Gemini rapidly generated a comprehensive initial list of risks spanning three distinct domains (ethical, safety, security), covering all the major categories a human expert would identify. For a start-up management team without specialist risk expertise, this represents genuine value: it ensures that no major risk category is entirely overlooked at the outset of operations.

However, the assessment also exposed three significant limitations. First, depth and justification: Gemini's initial outputs consistently lacked operational specificity. The safety risk of unsafe e-bike maintenance, for example, was identified correctly but without any explanation of the specific failure mechanisms (brake system wear, battery management faults, frame fatigue) that would be needed to inform a maintenance protocol. This required human expert augmentation before the output could be used.

Second, regulatory and legal context: Gemini did not proactively integrate UK-specific legal obligations (UK GDPR, Working Time Regulations, Equality Act) into its risk assessments, despite these being directly relevant to the scenario. This is a significant limitation for applied risk assessment in a UK regulatory context, where legal compliance is a first-order concern. The student had to supply this context explicitly through prompt refinement.

Third, trade-off reasoning: Gemini's handling of the emergency communication failure risk in Q2.2 demonstrated a weakness in reasoning about low-probability/high-severity events. Ranking this risk at Priority 4 on likelihood grounds reflects a probabilistic approach to risk that does not align with established safety engineering practice for catastrophic hazards [2]. A human safety engineer would not have made this error.

In summary, GenAI is effective as a brainstorming and structuring tool, reducing the time required for initial risk identification and supporting communication with non-specialist audiences. It is not effective as a substitute for expert risk analysis, particularly where legal, regulatory, or domain-specific technical knowledge is required. A fourth limitation not illustrated in this assessment but essential to acknowledge is hallucination and factual plausibility. Gemini's outputs were internally coherent and appeared credible, but plausibility is not accuracy: AI-generated content may assert specific regulatory thresholds, incident

statistics, or technical standards that are confidently stated but factually incorrect. Every AI-generated risk statement in this submission was independently verified against primary sources before use. Without this verification step, AI-assisted risk assessment carries a structural risk of embedding undetected errors into a management document, which could be more harmful than no analysis at all.

(iv) Most Useful Source

The most useful single source consulted during this assessment was: Reason, J. Human Error. Cambridge University Press, 1990 [1].

This source was foundational to the analysis in three distinct ways. First, in Question 1.2(i), Reason's Skill-Rule-Knowledge framework and Generic Error Modelling System provided the theoretical basis for classifying the three HEHAZOP errors as action-based slip, lapse, and skill-based slip respectively. Without this taxonomy, the error classifications would have been intuitive rather than theoretically grounded, and the discussion of error mechanisms would have lacked precision.

Second, in Question 1.2(iii), Reason's account of the intermittent nature of slips and lapses in highly practised tasks supported the critique of the HEART result: the argument that routine tasks cannot be modelled as having near-unit failure probability is directly derived from Reason's analysis of the relationship between task familiarity and error frequency.

Third, in Questions 2.2 and 2.3, Reason's framework for understanding fatigue as a performance shaping factor particularly his account of the relationship between circadian rhythms, sustained attention, and human reliability provided the conceptual basis for the driver fatigue risk analysis and the justification of the working hours limitation recommendation.

No other single source spanned all three analytical dimensions of the assessment (human error analysis, safety risk assessment, and practical mitigation design) as effectively as Reason (1990).